INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat C Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

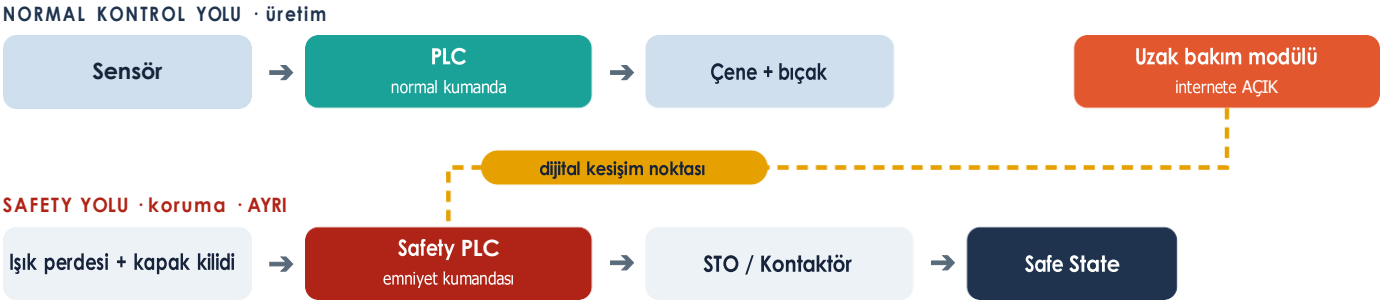
Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?
Sıcak yapıştırma çenesi ve film kesme bıçağı; el ve parmakta ezilme, kopma, kesilme ve yüksek ısıya bağlı yanıklar.

2. Safety function (emniyet fonksiyonu) hangisidir?
Işık perdesi ihlali veya koruma kapağı açıldığında > Safety PLC üzerinden STO tetiklenerek çene ve bıçak hareketinin enerjisinin kesilip anında durdurulması.

3. Safety-related control system nerede? Şemada işaretleyin.
Alttaki kırmızı renkli emniyet hattının tamamı.

4. Normal PLC ile Safety PLC farkı nedir?
Normal PLC üretim çevrimini yönetir ve iç donanım hatasında durmayabilir; Safety PLC yedekli çift işlemcili yapısıyla kendi iç hatasını algılar ve sistemi zorunlu olarak güvenli duruma (Fail-Safe) geçirir.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?
Risk seviyesine göre sistemin güvenilirlik şartını belirler; çene ve bıçakta uzuv kaybı ve ağır yaralanma riski bulunduğundan fonksiyonun yüksek bir güvenlik derecesine (PL d/e, SIL 2/3) sahip olması şarttır.

6. Safe state (güvenli durum) nedir?
Motorların torkunun kesildiği (STO), ısıtıcı çenelerin mekanik olarak açık konumda kilitlendiği ve insana zarar verebilecek tüm mekanik hareketlerin tamamen durduğu durumdur.

7. Safety function hangi dijital bağımlılıklara sahip?
Safety PLC içerisindeki emniyet yazılımı parametrelerine ve sarı kesikli hatla bağlı uzak bakım modülü üzerinden gelebilecek dijital konfigürasyon değişikliklerine.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?
Şemada gösterilen sarı kesikli "dijital kesişim noktası" üzerinden; internete açık uzak bakım modülünü ele geçiren saldırgan, Safety PLC parametrelerini değiştirip kilit veya ışık perdesi sinyalini yazılımsal olarak bypass edebilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Emniyet Bölgesi (Safety Zone): Emniyet PLC'si.
Kontrol / Hücre Bölgesi (Control Zone): Üretim PLC, HMI (port 80), motor sürücüleri, 2 kilitsiz USB.
Sınır / DMZ Bölgesi: İnternete açık uzak bakım modülü, "admin/admin" servis hesabı, bulut telemetri.
Kablosuz / Dış Erişim Bölgesi: Wi-Fi AP (parolası kartonda).

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Bölge: Dış sınır / DMZ bölgesine düşer.
İnternete doğrudan açık olması ve admin/admin hesabı taşıması kontrol bölgesine yetkisiz sıçramaya yol açar; mutlaka güvenlik duvarı arkasına ve kontrollü bir DMZ mimarisine taşınmalıdır.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Conduit 1 (Uzak Bakım / DMZ - Kontrol Zone): Firewall üzerinde; şifreli VPN tüneli, MFA kimlik doğrulaması ve bakım süresi kontrol edilir.
Conduit 2 (Wi-Fi AP - Kontrol Zone): Ağ geçidinde; 802.1X doğrulaması, MAC filtreleme ve yalnızca HMI web portuna (HTTP) kısıtlı yetki kontrol edilir.
Conduit 3 (Kontrol Zone - Emniyet Zone): Güvenlik köprüsünde; yalnızca tek yönlü durum okuma (Read-Only); dışarıdan Safety parametresi yazılması kesinlikle engellenir.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: Dış bağlantıyı doğrudan PLC'den kesmek ve DMZ'deki ara sunucuda izole etmek için.
Tünel?	Açık / VPN	VPN: Açık hatta şifresiz dolaşan paketlerin dinlenmesini ve ortadaki adam saldırılarını önlemek için.
Kimlik?	Parola / MFA	MFA: Statik şifrenin (admin/admin) çalınması riskine karşı iki aşamalı doğrulama zorunlu tutulmalıdır.
Hesap?	Paylaşılan / Kişisel	Kişisel: Ortak hesapları kaldırıp parametre değişikliklerinde kişi bazlı hesap verebilirlik sağlamak için.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: Olası sabotaj veya hatalı müdahalelerde adli delil ve denetim izi (audit trail) oluşturmak için.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: Saldırı yüzeyini asgariye indirmek için; kapı yalnızca yerel operatör onayıyla bakım süresince açılmalıdır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat C Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç.** Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Senaryo 1 (Fırsatçı Dış): Otomatik bot/hacker > İnternete açık uzak bakım modülü > Varsayılan admin/admin ile girip STO (Safe Torque Off) emniyetini bypass eder > Operatör müdahalesinde çene aniden kapanır, el-parmak ezilmesi ve ağır yanık oluşur.	3	3	3	27	Kritik
Senaryo 2 (Meraklı İçeriden): Hat operatörü > Panodaki Wi-Fi parolası ile yerel ağa bağlanır > Port 80 HMI web arayüzünden kesme zamanlamasını bozar > Operatör sıkışan ambalajı çekerken film kesme bıçağı erken iner, parmak kesilmesi/kopması meydana gelir.	3	3	2	18	Kritik
Senaryo 3 (Tedarik Zinciri / Taşeron): Servis personeli > Sahadaki kilitsiz USB portu > PLC'ye zararlı yazılım bulaştırıp optik ışık perdesini devre dışı bırakır > Koruma bariyeri çalışmaz, operatörün eli çenede kalır ve uzuv sıkışması gerçekleşir.	2	3	4	6	Orta (Öne Alınır: S=3)

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

Senaryo 1 (Fırsatçı Dış) en yüksek önceliklidir; çünkü internete doğrudan açık bir kapıdan varsayılan admin/admin yetkisiyle en yüksek maruziyet ve istismar kolaylığına (L=3, E=3) sahip olup doğrudan ağır uzuv kaybına (S=3) yol açarak maksimum risk puanı olan 27'ye (Kritik) ulaşmaktadır.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet; Senaryo 3 (Kilitsiz USB) yerel fiziksel erişim gerektirdiği için dış maruziyeti düşüktür (E=1) ve matematiksel puanı 6 (Orta) seviyesinde kalmıştır.
Nasıl görünür kılınır?: Kural uyarınca S=3 (insana kalıcı fiziksel zarar, uzuv kopması) içeren senaryolar skora bakılmaksızın doğrudan en üst öncelik listesine çekilir, matriste kırmızı uyarı etiketiyle vurgulanır ve USB engelleme önlemleri derhal ilk sıraya alınır.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

HEDEF (beş ilkeyle yeniden tasarlayın)

Mühendis > VPN (Şifreli Tünel) > MFA & Kişisel Hesap > Jump Server (DMZ) > Paketleme PLC (Tam oturum kaydı, varsayılan kapalı/süre sınırlı).

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Hayır, etkilenmez. Emniyet zinciri bağımsız bir Safety PLC üzerindedir; saldırgan internete açık uzak bakım modülünü ele geçirse bile fiziksel kapak kilidi ve ışık perdesi Safety PLC üzerinden donanımsal olarak torku keser (STO) ve bıçak/çeneyi durdurur.

2. Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   "Uzak bakım modülünde, haberleşme ağında veya üretim kontrol yazılımında oluşabilecek herhangi bir siber müdahale ya da arıza; ışık perdesi ve kapak kilidi güvenlik fonksiyonunun tehlikeli hareketleri anında durdurma ve makineyi güvenli duruma (Safe State) geçirme kabiliyetini hiçbir koşulda geçersiz kılamaz (bypass edemez), engelleyemez veya geciktiremez olmalıdır."

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: **SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Bileşen var mı: Evet, PaketPro PLC firmware kütüphanesi kullanılmaktadır.
Sürüm etkileniyor mu: Evet, makinedeki kütüphane sürümü 2.4'tür.
Açık ulaşılabilir mi: Evet, PaketPro'nun internete açık uzak bakım modülü üzerinden erişilebilir durumdadır.
Sonuç: Üç şart da karşılandığı için bu CVE sistemi doğrudan etkiler.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, hemen durdurulmaz. Üretim anında kesilirse paketleme hattında malzeme ziyanı, çenelerin sıcak yapışması ve plansız duruş maliyeti oluşur; bunun yerine uzaktan erişim portu fiziksel/mantıksal olarak derhal kapatılarak risk izole edilir ve ilk planlı duruşta müdahale edilir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test edilir. Doğrudan çalışan makineye yüklenmez; üretimden tamamen izole edilmiş bir laboratuvar/test tezgahında (FAT/staging panosu veya dijital ikiz ortamında) test edilerek çevrim süresini ve I/O tepkilerini bozmadığı doğrulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Etkileyebilir. Yamanın Safety PLC haberleşme bloklarına veya güvenlik mantığına dokunup dokunmadığına, özellikle Safety Signature / Checksum (sağlama toplamı - CRC) değerinin değişip değişmediğine bakılarak anlaşılır; sağlama toplamı değişmişse sistem yeniden doğrulanmalıdır (re-validation).

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Açık barındıran PLC portu endüstriyel firewall ile tamamen erişime kapatılır, uzak bakım modülü devreden çıkarılır ve ağ seviyesinde bu zafiyetin istismar imzalarını engelleyen derin paket denetimli (DPI) bir IPS kuralı devreye alınır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Kimi ararsınız: OT Güvenlik Sorumlusu ve Hat Bakım Mühendisi.
   İlk 3 Eylem:Işık perdesi parametreleri belirsiz olduğundan çalışanları derhal çene ve bıçak tehlike bölgesinden uzaklaştırmak.
   Cihazları resetlemeden/kapatmadan uzak bakım modülünün ağ kablosunu çekerek hattı izole etmek.
   Gece 03:00'te bağlanan servis hesabının aktif tüm oturumlarını sonlandırmak.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Emniyet güvende mi / Nasıl doğrulanır: Işık perdesi doğrulanmadığı için henüz güvende değildir; Safety PLC'nin emniyet sağlama toplamı (Safety CRC / Signature) son onaylı yedekle kıyaslanarak ve fiziksel test yapılarak doğrulanır. Hangi kanıt korunur: PLC'nin uçucu bellek kopyası (RAM dump), güvenlik duvarı (firewall) bağlantı logları ve uzak oturum izleri (cihaz kesinlikle kapatılıp resetlenmeden). Hangi hesap kapatılır: Gece 03:00'te tanınmayan konumdan giriş yapılan harici servis hesabı dondurulur/kapatılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Zafiyetin/olayın tespit zamanı (10:15), yetkisiz erişim saati (gece 03:00), etkilenen varlık (PaketPro PLC / Işık perdesi hattı), olayın aktif yayılma durumu ve operasyonel emniyet riski taşıyıp taşımadığı bilgisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök Neden: Servis hesabı kimlik bilgilerinin sızdırılması ve açık kalan uzaktan erişim kapısı. Etki: Işık perdesi parametrelerinde manipülasyon şüphesi, güvenlik amacıyla üretim hattının planlı duruşu. Önlem & Kim ne yapıyor: OT Ekibi doğrulanmış altın yedeği (golden backup) PLC'ye yükler; IT/Siber Güvenlik ekibi MFA ve IP kısıtlamalarını zorunlu kılar; Güvenlik Mühendisi ışık perdesi doğrulamasını yapıp hattı üretime teslim eder.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak erişim ve ağ geçidi bağlantı IP/oturum kayıtları, PLC konfigürasyon denetim logları (Audit Trail), Safety PLC sağlama toplamı doğrulama tutanakları ve adli bilişim (forensic) müdahale raporları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad | Grup | Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: PaketPro'ya YZ'li görsel paket kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?
   Hatta bağımsız ikinci bir mekanik/sensör kontrolü (örneğin paket kalınlık/yükseklik sviçi veya tartı/load cell) bulunmalıdır. Uyuşmazlıkta parça ret mekanizmasıyla ayrılmalı ve HMI üzerinden operatör uyarılıp manuel denetim (Human Override) istenmelidir.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?
   Bağımsız bir izleme (Monitoring) katmanı görüntü karesi frekansını (FPS), zaman damgasını ve sinyal gürültüsünü denetler. Veri donması veya bozulmasında girdi şüpheli sayılır; YZ devreden çıkarılarak kural tabanlı emniyetli çalışma moduna (Fallback) geçilir ve hat güvenli hızda tutularak operatöre alarm verilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?
   Güven eşiği (Confidence Threshold) en az %90 (0.90) olmalıdır. Eşiğin altında kalan parçalar varsayılan olarak reddedilmeli (RED/Ret mekanizması), sistem kural tabanlı emniyetli moda (Fallback) geçmeli ve şüpheli paket operatör denetimine (Human on the loop / İnsana sor) iletilmelidir.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	**İkincil sensör doğrulaması ile paket ret hattına aktarılır; operatör paneline uyarı verilerek manuel inceleme sağlanır (Fail-Safe & Human Override).**
Girdi manipüle edildi	**Kamera veri akışındaki donma/anomali izleme servisiyle saptanır; YZ kararları durdurulup temel sensör kurallarına dönülür (Monitoring & Fallback).**
Confidence düştü	**Güven skoru <%90 ise şüpheli kabul edilerek ret pistonuyla ayrılır, hat hızı düşürülür ve operatör onayına yönlendirilir (Confidence Threshold & Fallback).**

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.